

隐藏信息接管k8s集群

最近在恶补一些体系框架，想到之前遇到的一个攻防场景，做个分享，非科普向。

很多人都分享过未授权场景的利用，但是关于证书认证、token认证下攻防的场景不是很多。

基础概念补全

K8S

k8s全称kubernetes，是一个开源的，用于管理云平台中多个主机上的容器化应用的编排管理工具，提供了应用部署，规划，更新，维护的一种机制，可简单理解为容器集权设备。kubernetes 又涉及到几个核心组件，其中，apiserver提供了资源操作的唯一入口，操作基本上都是通过 apiserver 这个组件进行的，它提供 HTTP RESTful 形式的 API 供集群内外客户端调用。kubernetes 对于访问 API 来说提供了三个步骤的安全措施：认证、授权、准入控制，当用户使用 kubectl, client-go 或者 REST API 请求 apiserver 时，都要经过以上三个步骤的校验。后面又涉及到Master节点、Node（Worker）节点、最小工作单元Pod及服务，后续再科普。



Kubectl¹

命令行工具管理 Kubernetes 集群。

K8S API 认证

kubernetes 目前所有的认证策略（Authentication）如下所示：

- X509 client certs
- Static Token File
- Bootstrap Tokens
- Static Password File
- Service Account Tokens
- OpenId Connect Tokens
- Webhook Token Authentication
- Authenticating Proxy
- Anonymous requests
- User impersonation
- Client-go credential plugins

kubernetes 目前支持如下四种鉴权（Authorization）机制：

- Node
- ABAC
- RBAC
- Webhook

Linux 信息收集Tips

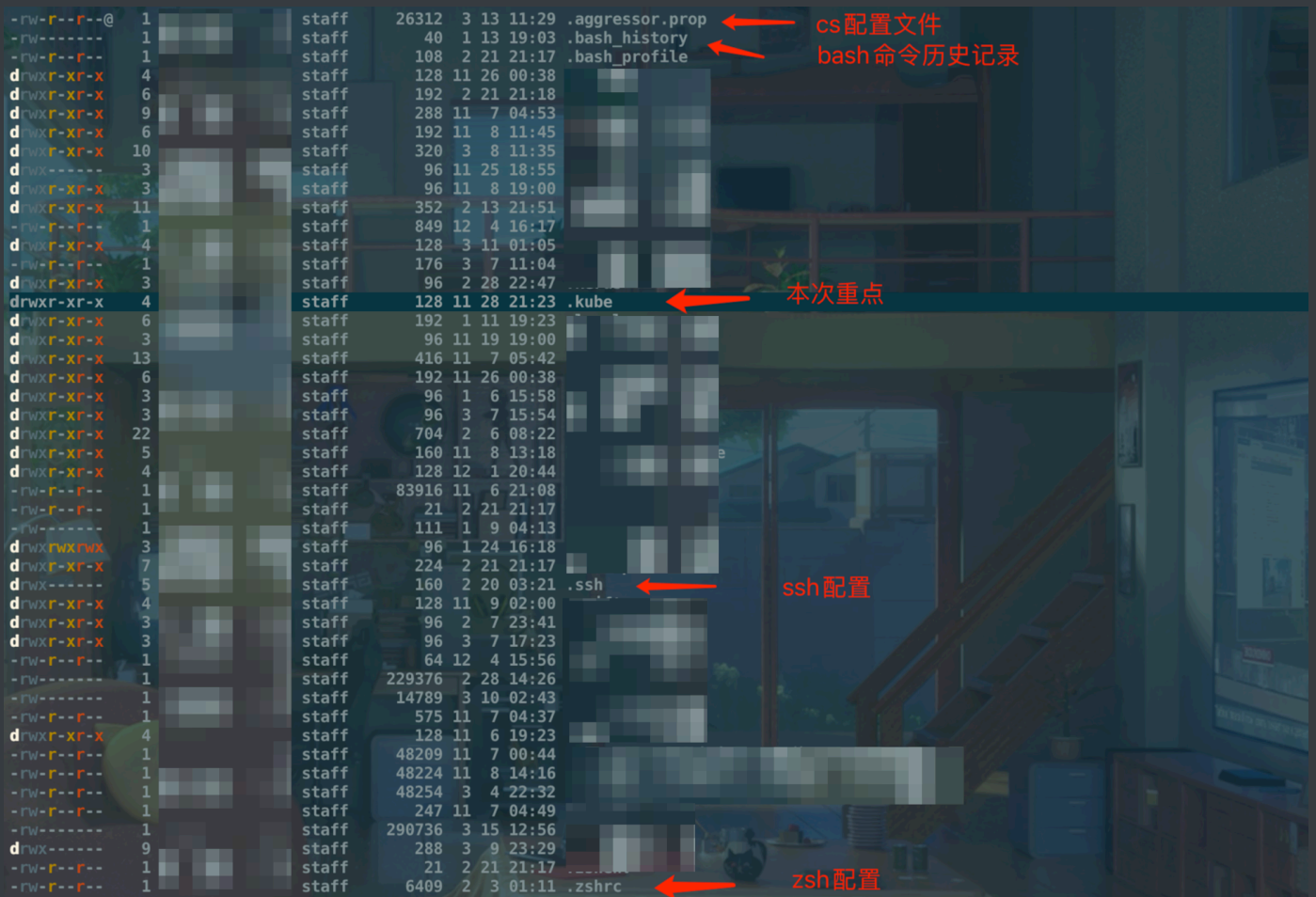
为什么忽然提及到Linux信息收集呢，如果工作环境为Mac或者unix系系统可能比较了解，比如 `ls` 和 `ls -al` 的区别，`$HOME` 路径下面 `.xxx` 这些一些服务应用所代表的配置，举几个例子

`.aggressor.prop` 里面记录了你Cobalt Strike的所有配置，包括连接地址、用户名、密码、插件加载等

`.bash_history`和`.ssh` 不多赘述

.kube 本次重点

.zshrc 使用zsh终端的配置文件，可做权限维持



本次场景

二层网络中拿到一台服务器权限，查看.bash_history发现存在Kubectrl运维记录，但是未发现相关user、password参数，翻文件发现.kube文件夹。

```
drwxr-xr-x.  4 root root  .
dr-xr-x---. 21 root root  ..
drwxr-x---.  3 root root  cache
-rw-r--r--.  1 root root  config
drwxr-x---.  3 root root  http-cache
-rw-r--r--.  1 root root  k8s. .conf
-rw-r--r--.  1 root root  k8s. .conf
-rw-r--r--.  1 root root  k8s. .conf
```

查看clusters.cluster.server发现，三套集群分别为aliyun上提供对外业务集群、第三层网络生产环境集群、测试集群配置文件，里面具体含义后续补充。

[illegible]

提供一个简单的本地连接方式，内网走代理，在本地mkdir .kube，然后copy conf到本地.kube/config

```
~/ .kube
→ cat config | head -n 3
apiVersion: v1
clusters:
- cluster:
```

然后后续和k8s匿名访问利用方法一样。

- 集群不算很大，最后获取近万台容器权限而已。

```
[root@tmp]# cat /etc/passwd | grep root -- /bin/bash
root:x:0:0:root:/root:/bin/bash
root:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
root:x:2:2:bin:/bin:/usr/sbin/nologin
root:x:3:3:sys:/bin:/usr/sbin/nologin
root:x:4:4:games:/bin:/usr/sbin/nologin
root:x:5:5:uucp:/bin:/usr/sbin/nologin
root:x:6:6:man:/bin:/usr/sbin/nologin
root:x:7:7:lp:/bin:/usr/sbin/nologin
root:x:172:178:root:/root:/bin/bash
```

想起一句话："用机制去对抗机制，以运维思维去打攻防。"

从今天起，做一个运维吧，同事那么厉害，被卷死了，还可以转个行。



The Cloud Native Computing Foundation hereby certifies that



has successfully completed the program
requirements to be recognized as a

Certified Kubernetes Administrator